NEURALMATRIX / ACCESSPROOF

Customer Onboarding Guide

Microsoft 365 + SharePoint • Customer-side Guard & Gateway • Verified RAG protection

Edition: 05 November 2026. Updated to the current UI, backend permission model, and validated installation contracts. Screenshots use **synthetic test data**. This guide is issued for **pilot review**: do not present it as a completed independent customer certification.

THE EIGHT PHASES

1–2 Authorize	3–5 Connect	6–8 Verify
Register workspace; consent to the chosen SharePoint site.	Enroll Guard; register RAG; install Gateway on a private host.	Certify the real route; Owner approves; test live employees.

Security principle: No installer receipt, source sync, dashboard label, or chat answer can replace independent permissions evidence and signed route certification. Protect is fail-closed.

What we do not require: a public RAG URL, a Microsoft password pasted into the website, or any NeuralMatrix AWS credentials on a customer host.

Before you begin

Arrange the people and access below before opening the onboarding form. The customer chooses and approves the data boundary.

Role	Responsibility
Workspace Owner	Signs in, registers the AI application, reviews the route certificate, gives final human approval.
Microsoft 365 / SharePoint admin	Consents to the tenant application and separately approves an explicit grant to the chosen site.
RAG / IT owner	Operates the private host, Docker stack, Guard, Gateway and agreed test route.
Two test employees	Use different Microsoft accounts with approved and denied access to a synthetic test document.

Preflight checklist

- Microsoft 365 tenant with provisioned SharePoint Online site and document library.
- Verified tenant, site, library, drive and approved root DriveItem IDs. No site picker is available yet.
- Private customer-owned Linux RAG host with Docker and a reviewed integration path.
- Employee SSO issuer and audience known; no ID-token-for-access-token substitution.
- Customer security team has reviewed the potential selected-site elevated permission grant.
- A plan for signed, in-flight and post-revocation testing without exposing real documents.

Bounded scope: For early pilots, use one SharePoint site and one selected chatbot. Never silently scan hosts, enable unrelated chatbots, or broaden a Microsoft tenant grant.

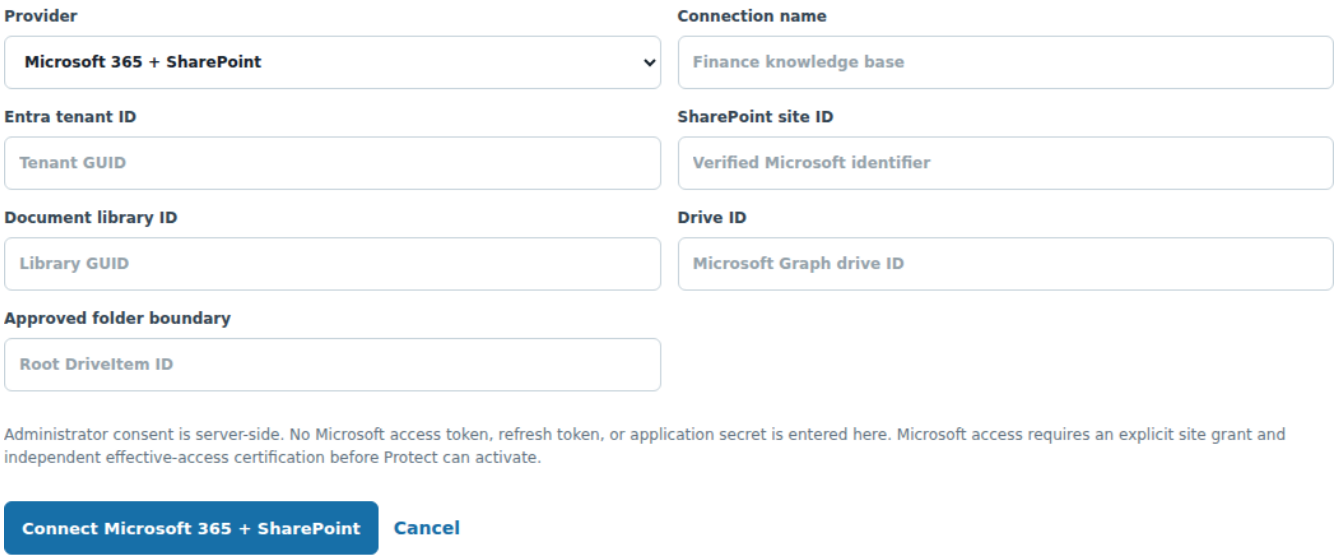
1 Create your workspace

- Open **app.accessproof.in/register** and create the organization Owner account.
- Verify the email address and sign in. Enable MFA before using production data.
- Confirm the selected organization and the **Owner** role in the workspace menu.

2 Connect SharePoint

On **Permission sources**, choose **Microsoft 365 + SharePoint**. Enter the customer's verified IDs and approved folder boundary. Consent is initiated from the browser; AccessProof never asks for a Graph bearer token in the form.

Current form (synthetic data, after layout fix)



You're done when: the source reports a valid connection and both directory and ACL synchronization are fresh. Fresh source state is necessary but not sufficient for production Protect.

2 Two independent Microsoft grants

First: tenant admin consent. The administrator approves the configured Entra application permissions. With **Sites.Selected**, consent alone gives the AccessProof service principal access to **zero sites**.

Second: selected-site grant. A separately authorized administrator grants the approved AccessProof application access to the named SharePoint site. The grant is not made by AccessProof itself.

- If the callback says **Site grant required**, that is a safe, expected intermediate state. Valid consent is retained.
- Have the tenant admin issue the reviewed grant to the **approved site only**.
- Return to the same source and click **Validate**; re-consent is not necessary solely because a site grant was added.
- Wait for new employee/group and ACL synchronization. Verify scope, identity and effective permissions before Protect.

> **Important security review:** Our November 2026 production-equivalent certification used the **site-scoped fullcontrol** role for effective-permission operations. This is elevated access even though it is confined to the selected site. **Never imply read-only is already certified, or grant fullcontrol without explicit customer security approval.** The app must not silently request tenant-wide Sites.FullControl.All.

Operational reminder: A successful consent callback is not a permission certificate. Source health and every application protection gate remain independently enforced.

3 Enroll the customer Guard

- Create a Guard and download its official installer from the dashboard.
- Run the installer on the customer-controlled host. Enter the one-time enrollment token in its local setup page.
- Set the trusted Microsoft OIDC issuer/audience used by the RAG. Verify the Guard can fetch a current signed policy.
- Confirm both **connected** and **security ready**; heartbeat alone does not prove source permissions or route enforcement.

4 Register exactly one AI application

- Open AI Applications; register a stable application ID, display name and the supported AccessProof Gateway contract.
- Bind the enrolled Guard and the explicitly approved SharePoint source.
- Keep the source, tenant and route configuration fixed for certification; later changes invalidate relevant approvals.

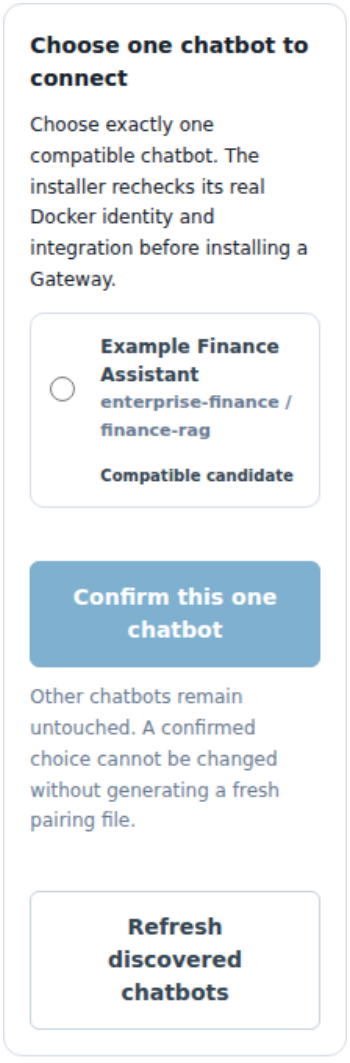
> **You're done when:** your customer host Guard has a current policy, the application is bound correctly, and the dashboard does not report missing source/Guard prerequisites.

5 Connect the real RAG

Path A: Supported Docker Compose RAG

- From Get Started, download the reviewed Gateway connector ZIP and the one-time pairing file.
- On the **private** customer Docker host, run **python3 ~/Downloads/accessproof-gateway-connector.zip**.
- The installer discovers local eligible RAGs without requesting an exposed RAG URL.
- Choose **one** chatbot in the dashboard. Unsupported applications require a separate reviewed integration.
- Confirm Gateway pairing, signed routing and local connectivity. Installation does **not** turn on Protect.

What the customer selects



Synthetic chatbot picker after the responsive layout correction.

5 Alternative RAG framework path

For an existing Python, LangChain or LlamaIndex RAG, a reviewed SDK and Gateway TLS integration can be used. This path is **not** an automatic conversion and currently requires agreed engineering assistance and route certification.

- The Python client is kept in **integrations/rag-clients/python** and was **not published on PyPI** at this review.
- Receive a reviewed client wheel through a customer-approved distribution channel, then install its exact supplied wheel file with pip.
- Configure Gateway TLS trust, delegated employee access tokens, signed retrieval and trusted document provenance.
- No private key, API token, Microsoft password or customer RAG content is embedded in source code or installer archives.

Correct installation command: `python3 -m pip install ./accessproof_rag-0.1.0-py3-none-any.whl` when that reviewed wheel has been supplied. Do **not** use the previous guide's unverified `pip install accessproof-rag` from PyPI.

Installer distribution checkpoint

Before providing this step to customers, the deployment owner must confirm the authenticated **/downloads/accessproof-gateway-connector.zip** route serves an actual ZIP and that its SHA-256 matches the reviewed, published release. An unauthenticated redirect to /login is not evidence that the artifact itself is present.

6 Certify the actual RAG route

Agree on a short, authorized test window. The RAG owner or a temporary approved AccessProof engineer runs the signed challenges on the **customer-controlled host**.

- Run nonce-bound Gateway challenges against the real employee-facing route, with independent Guard audit correspondence.
- Verify valid source certification, allowed/denied employee access, and that unauthorized chunks never reach the model.
- Verify rejection of forged content and routes, fail-closed Guard outages and cache/revocation reuse protections.
- Keep test identities ephemeral; restore any synthetic permission changes and revoke temporary host access when finished.
- Review the server-authoritative route certificate and all Protect gates. A green installer cannot substitute for these checks.

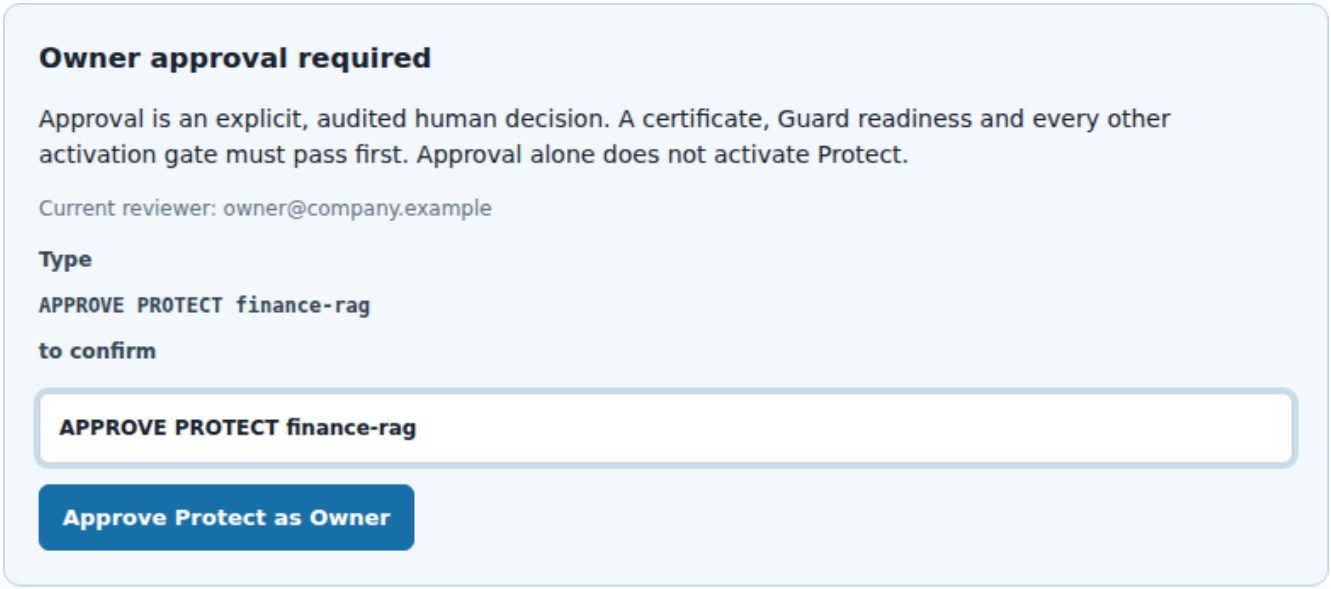
Not self-service yet: The safe route-certification path still requires agreed access to the actual RAG host and real signed evidence. Do not bypass this requirement or claim automatic certification of arbitrary RAGs.

7 Owner approval and activation

Once every other security gate passes and the current customer-facing route is certified, the signed-in organization **Owner** opens **AI Applications** → **Check & Enable Protection**.

- Read the active route and source certificate state. Confirm the intended customer deployment.
- Type exactly **APPROVE PROTECT <application_id>** in the Owner approval field.
- Click **Approve Protect as Owner**. This is audited and rejected for Admins, API keys and stale routes.
- Click **Enable Protection**. Wait for Guard acknowledgment and independent **PROTECTED_VERIFIED** state.
- A recertified/changed route requires new human approval. Never force-enable failed gates.

Current Owner approval screen (synthetic data)



Approval is not activation: Successful approval creates an audited authorization decision, but the customer is not protected until the Guard acknowledges enforcement and all live security checks pass.

8 Test in the customer's chatbot

- Confirm backend state **PROTECTED_VERIFIED** for the right app, source, Guard and route.
- Have employee A sign in through their ordinary Microsoft SSO and ask a question about their approved test document.
- Have employee B sign in with a different account and ask about the same restricted document. It must not reach the model or appear in a released answer.
- Test a shared document that both can access and review Layer 1/Layer 2 authorization telemetry.
- When approved, revoke a test permission and verify denial after revocation, including cache and in-flight requests.
- Monitor signed evidence freshness and periodically re-certify when route or permissions change.

Go-live checklist

Must be true	Evidence
Selected-site permission approved	Admin sign-off; bounded tenant/site scope; grant reviewed
Source current	Connected + fresh directory / ACL snapshot
Guard & Gateway live	Authenticated heartbeat plus signed policy and route binding
Security gates passed	Signed current route + source certificates, no stale/forged evidence
Owner approval recorded	Interactive Owner audit after route certification
Protect verified active	Guard acknowledgment + successful live Alice/Bob tests

Troubleshooting & final review

What you see	What to do
Site grant required after consent	Have tenant admin issue reviewed selected-site grant; click Validate on existing source. Consent is retained.
Source not configured / stale	Confirm SharePoint provisioning, source IDs, directory/ACL sync, and effective-permission scope.
Guard connected, not ready	Check signed policy, source freshness and Guard verification; never convert heartbeat into readiness.
Gateway paired, route uncertified	Run approved signed customer RAG route challenge and real cutover evidence.
Owner approval unavailable	Only signed-in Owner can approve, and all other gates and route certification must already pass.
Package not found on PyPI	Obtain the reviewed wheel from AccessProof technical contact, with SHA-256 verification.

Definitions

Source: The customer's approved SharePoint site, drive and folder boundary.

Guard: Customer-side enforcement node applying current policy and independent authorization.

Gateway: Signed, customer-side AI traffic boundary used for protected requests.

Route certification: Time-scoped security evidence bound to the actual customer RAG route and deployment.

Owner approval: Audited human authorization separate from machine verification and Guard activation.

Before distribution: confirm deployment of these UI changes, the production Entra client ID, customer download checksum and that the support mailbox **admin@accessproof.in** receives external email. All screenshots in this guide use synthetic data; a fresh independent customer tenant walkthrough is still required.